

TASK 1

PURPLE TEAM REPORT – HAWKEYE LAB

1. Introduction

This report presents a Purple Team analysis of the HawkEye Lab who usually simulate attacks to test defence mechanisms and identify security gaps by combining Red Team attack simulation and Blue Team defensive investigation. The goal is to address the gap between offensive and defensive strategies by analysing attacker techniques and strengthening detection and response mechanisms.

2. Objective

- Analyse attacker techniques and behaviour
- Analyse incident response method and workflow
- Evaluate effectiveness of defense mechanisms and improve them
- Identify security gaps
- Strengthen overall security posture.

3. Overview of Attack and Defense Mechanisms

3.1. Attack Mechanism

The red team simulated a real-world multi-stage cyberattack with the intent of data exfiltration via SMTP where the attack vector was delivering a malicious payload via unencrypted HTTP, execution of malware on victim system and establishing command-and-control (C2C) with the attacker infrastructure.

3.2. Defense Mechanism

The blue team successfully detected the suspicious HTTP traffic, DNS queries, abnormal SMTP traffic indicating data exfiltration, indicators of compromise, investigated the whole process, reconstructed the attack timeline and eradicated it to prevent further damage.

4. Methodology

A collaborative Purple Team approach was followed, combining Red Team attack simulation and Blue Team defensive analysis.

4.1. Tools Used

- Wireshark – analyses network traffic
- CyberChef – decodes Base64 encoded data
- Windows PowerShell – retrieves the file hash for malware verification
- IPlocation.net – provides geolocation of an IP Address.

4.2. Attack Methodology – Cyber Kill Chain

1. Reconnaissance

- The attacker finds a potential target according to their attack vector.
- This targeted approach allows attacker to exploit the user behavior rather than technical vulnerabilities.
- Gather basic information regarding the target environment for successful delivery of the attack.

2. Weaponization

- The attacker creates a malicious executable payload, **tkraw_Protected99.exe** to execute on the target system.

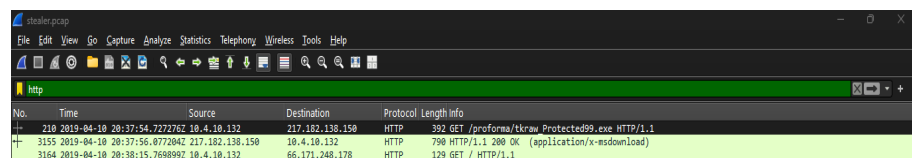
```
Hypertext Transfer Protocol
> GET /proforma/tkraw_Protected99.exe HTTP/1.1\r\n
Accept: */*\r\n
Accept-Encoding: gzip, deflate\r\n
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;
```

Figure 4.2.2.

- Sets up infrastructure where it configures an external server to host the malicious payload domain **proforma-invoices.com**.
- The payload establishes connection between target and the attacker systems to facilitate data exfiltration.
- The payload may be obfuscated to evade signature-based detection mechanisms.

3. Delivery

- The payload is delivered to the target over a HTTP network through a HTTP server.



No.	Time	Source	Destination	Protocol	Length	Info
210	2019-04-10 20:37:54.7227262	10.4.10.132	217.182.138.150	HTTP	392	GET /proforma/tkraw_Protected99.exe HTTP/1.1
3155	2019-04-10 20:37:56.8772042	217.182.138.150	10.4.10.132	HTTP	790	HTTP/1.1 200 OK (application/x-msdownload)
3164	2019-04-10 20:38:15.7698992	10.4.10.132	66.171.248.178	HTTP	129	GET / HTTP/1.1

Figure 4.2.3.(a)

- The victim downloads the executable file from the malicious domain, **proforma-invoices.com**.

```
Host: proforma-invoices.com\r\n
Connection: Keep-Alive\r\n
\r\n
[Response in frame: 3155]
[Full request URI: http://proforma-invoices.com/proforma/tkraw_Protected99.exe]
```

Figure 4.2.3.(b)

- The use of unencrypted HTTP allows the attacker to bypass secure detection mechanisms and deliver the payload without encryption.

4. Exploitation

- The victim system uses outdated OS **Windows NT 6.1**, which could act as a vulnerability.

```
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;
Host: proforma-invoices.com\r\n
Connection: Keep-Alive\r\n
```

Figure 4.2.4.

- The victim downloads the malicious file, **tkraw_Protected99.exe**, which is a possible phishing or a social engineering attack. Once the file is executed, the malware runs on the system and initiates further actions.

5. Installation

- After execution, the malware installs itself on the victim system.
- It then prepares the system for control by the attacker infrastructure thus modifies system behaviour.
- The malware may also form persistent mechanisms if it goes undetected for a long time.

6. Command-and-Control (C2C)

- The malware establishes connection with the attacker system using DNS queries for direct IP communication, **217.182.138.150** to continue further actions.

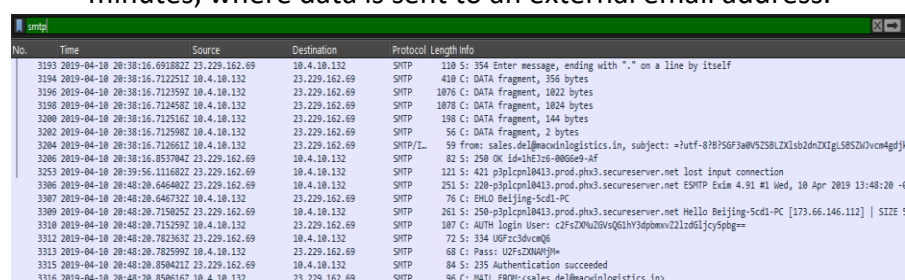
```
Internet Protocol Version 4, Src: 10.4.10.132, Dst: 217.182.138.150
Transmission Control Protocol, Src Port: 49204, Dst Port: 80, Seq: 1, Ack: 1, Len: 338
```

Figure 4.2.6.

- To maintain persistent access, the attacker periodically communicates with the victim system.

7. Action and Objective

- Attacker exfiltrates sensitive information using SMTP every 10 minutes, where data is sent to an external email address.



No.	Time	Source	Destination	Protocol	Length	Info
3193	2019-04-10 20:38:16.6918822	10.4.10.132	23.229.162.69	SMTP	110	S: 354 Enter message, ending with "." on a line by itself
3194	2019-04-10 20:38:16.7122512	10.4.10.132	23.229.162.69	SMTP	410	C: DATA Fragment, 356 bytes
3196	2019-04-10 20:38:16.7123592	10.4.10.132	23.229.162.69	SMTP	1076	C: DATA Fragment, 1022 bytes
3198	2019-04-10 20:38:16.7124582	10.4.10.132	23.229.162.69	SMTP	1078	C: DATA Fragment, 1024 bytes
3200	2019-04-10 20:38:16.7125162	10.4.10.132	23.229.162.69	SMTP	198	C: DATA Fragment, 144 bytes
3202	2019-04-10 20:38:16.7125982	10.4.10.132	23.229.162.69	SMTP	56	C: DATA Fragment, 2 bytes
3204	2019-04-10 20:38:16.7126612	10.4.10.132	23.229.162.69	SMTP/L	59	from: sales.del@macwinlogistics.in, subject: =?utf-8?B?3a0W5ZSBLZXlsb2dnZXIgLjS8S2UvcnA4djk=
3206	2019-04-10 20:38:16.8537042	23.229.162.69	10.4.10.132	SMTP	82	S: 250 OK id=1HE7z6-0066e9-AF
3253	2019-04-10 20:39:56.1116822	23.229.162.69	10.4.10.132	SMTP	121	S: 421 p3plcpn10413.prod.phx3.secureserver.net lost input connection
3306	2019-04-10 20:40:20.6464022	23.229.162.69	10.4.10.132	SMTP	251	S: 220 p3plcpn10413.prod.phx3.secureserver.net ESMTP Exim 4.91 #1 Wed, 10 Apr 2019 13:48:20 -4
3307	2019-04-10 20:40:20.6467322	10.4.10.132	23.229.162.69	SMTP	76	C: ENLD Beijing-Scd1-PC
3309	2019-04-10 20:40:20.7159252	23.229.162.69	10.4.10.132	SMTP	261	S: 250 p3plcpn10413.prod.phx3.secureserver.net Hello Beijing-Scd1-PC [173.66.146.112] SIZE 5
3310	2019-04-10 20:40:20.7159592	10.4.10.132	23.229.162.69	SMTP	107	C: AUTH Login User: c2FsZD0u2GVsQ6lhY3dpbm9vZ2lzd6lcy5pbG==
3312	2019-04-10 20:40:20.7823632	23.229.162.69	10.4.10.132	SMTP	72	S: 334 UGFzc3dvcmQ=
3313	2019-04-10 20:40:20.7825992	10.4.10.132	23.229.162.69	SMTP	68	C: Pass: UGFzc3dvcmQ=
3315	2019-04-10 20:40:20.8594212	23.229.162.69	10.4.10.132	SMTP	84	S: 235 Authentication succeeded
3316	2019-04-10 20:40:20.8596162	10.4.10.132	23.229.162.69	SMTP	96	C: MAIL FROM:<sales.del@macwinlogistics.in>

Figure 4.2.7.

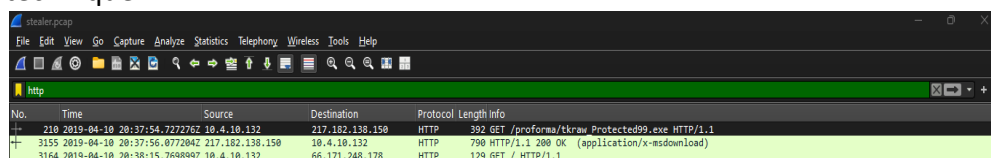
- The use of mail-based exfiltration allows the attacker to blend malicious activity with legitimate ongoing traffic making it easier to go undetected and continue the process for a long time.

4.3. Defence Methodology – Incident Response Lifecycle

I. Detection Analysis

1. HTTP Detection

An executable file is detected to be downloaded over **unencrypted HTTP** rather than a secure HTTPS protocol. This is a common malware delivery technique.



No.	Time	Source	Destination	Protocol	Length	Info
210	2019-04-10 20:37:54.7272762	10.4.10.132	217.182.138.150	HTTP	392	GET /proforma/tkraw_Protected99.exe HTTP/1.1
3155	2019-04-10 20:37:56.8772042	217.182.138.150	10.4.10.132	HTTP	790	HTTP/1.1 200 OK (application/x-msdownload)
3164	2019-04-10 20:38:15.7698992	10.4.10.132	66.171.248.178	HTTP	129	GET / HTTP/1.1

Figure 4.3.1.1.

2. DNS Detection

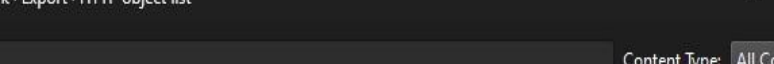
DNS queries sent to unusual domain, **proforma-invoices.com** that looks suspicious indicating command-and-control (C2C) communication.

```
Hypertext Transfer Protocol
  GET /proforma/tkraw_Protected99.exe HTTP/1.1\r\n
  Accept: */*\r\n
  Accept-Encoding: gzip, deflate\r\n
  User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;\r\n
  Host: proforma-invoices.com\r\n
  Connection: Keep-Alive\r\n
  \r\n
  [Response in frame: 3155]
  [Full request URI: http://proforma-invoices.com/proforma/tkraw_Protected99.exe]
```

Figure 4.3.1.2.

3. Malware Detection

The presence of a suspicious .exe file, **tkraw_Protected99.exe** indicates existence of malware.



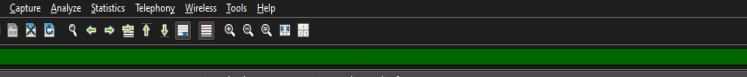
The screenshot shows the 'Export' dialog box in Wireshark, specifically the 'HTTP object list' tab. The window title is 'Wireshark · Export · HTTP object list'. At the top, there is a 'Text Filter:' input field and a 'Content Type:' dropdown menu set to 'All Content-Types'. Below this is a table listing the objects to be exported. The table has five columns: 'Packet', 'Hostname', 'Content Type', 'Size', and 'Filename'. The data rows are as follows:

Packet	Hostname	Content Type	Size	Filename
3155	proforma-invoices.com	application/x-msdownload	2025 kB	tkraw_Protected99.exe
3166	bot.whatismyipaddress.com	text/html	14 bytes	\
3297	bot.whatismyipaddress.com	text/html	14 bytes	\
3384	bot.whatismyipaddress.com	text/html	14 bytes	\
3469	bot.whatismyipaddress.com	text/html	14 bytes	\
3584	bot.whatismyipaddress.com	text/html	14 bytes	\
3839	bot.whatismyipaddress.com	text/html	14 bytes	\
3917	bot.whatismyipaddress.com	text/html	14 bytes	\

Figure 4.3.1.3.

4. Data Exfiltration Detection

Unusual **SMTP** traffic can be detected by monitoring outgoing network traffic involving sharing sensitive data and abnormal patterns of frequent data transfer every **10 minutes**.



The image shows a Wireshark packet capture of SMTP traffic. The packet list on the left shows several SMTP messages. The packet details pane on the right shows the structure of an SMTP message, including the envelope and the message body. The message body contains a subject line and a body text.

No.	Time	Source	Destination	Protocol	Length	Info
3194	2019-04-10 20:38:16.712251	10.4.10.132	23.229.162.69	SMTP	410	C: DATA fragment, 356 bytes
3196	2019-04-10 20:38:16.712392	10.4.10.132	23.229.162.69	SMTP	1076	C: DATA fragment, 1022 bytes
3198	2019-04-10 20:38:16.7124592	10.4.10.132	23.229.162.69	SMTP	1078	C: DATA fragment, 1024 bytes
3200	2019-04-10 20:38:16.712562	10.4.10.132	23.229.162.69	SMTP	198	C: DATA fragment, 144 bytes
3202	2019-04-10 20:38:16.7125982	10.4.10.132	23.229.162.69	SMTP	56	C: DATA fragment, 2 bytes
3204	2019-04-10 20:38:16.7126612	10.4.10.132	23.229.162.69	SMTP/L	59	From: sales.d@macwinlogistics.in, subject: ?utf-8?75GF3bZ5V5ZLx1sb2dnXIGjLSBZ5Ujv4mC
3206	2019-04-10 20:38:16.8537842	23.229.162.69	10.4.10.132	SMTP	82	250 OK 10.4.10.132-0006E-4F
3210	2019-04-10 20:38:16.1116822	23.229.162.69	10.4.10.132	SMTP	421	350ipcm10413.prod.ph3.secureserver.net lost input connection
3296	2019-04-10 20:48:20.6464022	23.229.162.69	10.4.10.132	SMTP	251	20 ipcm10413.prod.ph3.secureserver.net ESMTX En4.9.1 Mied, 10 Apr 2019 13:48:20
3307	2019-04-10 20:48:20.6467322	10.4.10.132	23.229.162.69	SMTP	76	C: EHLO Beijing-Scdi-PC
3309	2019-04-10 20:48:20.7150252	23.229.162.69	10.4.10.132	SMTP	261	250-350ipcm10413.prod.ph3.secureserver.net Hello Beijing-Scdi-PC [173.66.146.112] SIZ
3310	2019-04-10 20:48:20.7152582	10.4.10.132	23.229.162.69	SMTP	187	C: AUTH LOGIN User: c2f5ZmZuZ5V5ZLx1sb2dnXIGjLSBZ5Ujv4mC
3312	2019-04-10 20:48:20.7303632	23.229.162.69	10.4.10.132	SMTP	72	334 UGFC3bZ5V5ZLx1sb2dnXIGjLSBZ5Ujv4mC
3313	2019-04-10 20:48:20.7825992	10.4.10.132	23.229.162.69	SMTP	68	C: Pass: UZFZNXMYH=
3315	2019-04-10 20:48:20.8504212	23.229.162.69	10.4.10.132	SMTP	84	235 Authentication succeeded
3316	2019-04-10 20:48:20.8506162	10.4.10.132	23.229.162.69	SMTP	96	C: MAIL FROM:sales.d@macwinlogistics.in>
3318	2019-04-10 20:48:20.9146272	23.229.162.69	10.4.10.132	SMTP	82	C: 250 OK

Figure 4.3.1.4.

5. Indicators of Compromise (IoCs)

- **Malicious Domain**

proforma-invoices.com was the domain used by the victim system to download a suspicious file.

```
Host: proforma-invoices.com\r\n
Connection: Keep-Alive\r\n
\r\n
[Response in frame: 3155]
[Full request URI: http://proforma-invoices.com/proforma/tkraw_Protected99.exe]
```

Figure 4.3.1.5.(a)

- **Malicious IP address**

217.182.138.150, extracted by investigating the malicious domain, used for communication.

```
Internet Protocol Version 4, Src: 10.4.10.132, Dst: 217.182.138.150
Transmission Control Protocol, Src Port: 49204, Dst Port: 80, Seq: 1, Ack: 1, Len: 338
Hypertext Transfer Protocol
  GET /proforma/tkraw_Protected99.exe HTTP/1.1\r\n
  Accept: */*\r\n
  Accept-Encoding: gzip, deflate\r\n
  User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0; SLCC2;
```

Figure 4.3.1.5.(b)

- **Victim Machine IP**

10.4.10.132, internal system initiating suspicious traffic with large amount of data transfer and malware download.

Ethernet · 7	IPv4 · 12	IPv6	TCP · 48	UDP · 58			
Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country
10.4.10.2	42	5 kB	0	0 bytes	42	5 kB	
10.4.10.4	513	114 kB	234	46 kB	279	68 kB	
10.4.10.132	4,003	2 MB	1,993	212 kB	2,010	2 MB	
10.4.10.255	30	3 kB	0	0 bytes	30	3 kB	
23.229.162.69	280	39 kB	161	13 kB	119	26 kB	
66.171.248.178	63	5 kB	28	3 kB	35	2 kB	
216.58.193.131	20	8 kB	11	6 kB	9	3 kB	
217.182.138.150	2,947	2 MB	1,576	2 MB	1,371	74 kB	
224.0.0.22	23	1 kB	0	0 bytes	23	1 kB	
224.0.0.252	10	750 bytes	0	0 bytes	10	750 bytes	
239.255.255.250	74	29 kB	0	0 bytes	74	29 kB	
255.255.255.255	1	342 bytes	0	0 bytes	1	342 bytes	

Figure 4.3.1.5.(c)

- **Malicious File Name**

tkraw_Protected99.exe, .exe indicates executable file indicating malware.

```
Hypertext Transfer Protocol
  GET /proforma/tkraw_Protected99.exe HTTP/1.1\r\n
  Accept: */*\r\n
  Accept-Encoding: gzip, deflate\r\n
  User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;
```

Figure 4.3.1.5.(d)

II. Investigation

1. Alert Triage

The incident can be considered as **high-alert** as there is malware detected and continuous data exfiltration activity. By correlating data sources and victim activity, false positives can be ruled out.

2. Log Analysis

- Network traffic logs were analysed using Wireshark to identify suspicious communication patterns.
- Use of HTTP for communication indicates suspicious data transfer.

3. Root Cause Analysis

- The root cause of the attack was identified as the download of the executable file **tkraw_Protected99.exe** from an untrusted source over HTTP. This indicates a possible phishing or a social engineering attack where the victim was tricked into downloading the file.
- The lack of secure HTTPS communication allowed the attack to go undetected.

4. Attack Timeline

- a) Victim IP – 10.4.10.132 attempts to access a suspicious domain, **proforma invoices.com**.
- b) DNS query sent to DNS server- 10.4.10.4, receives IP address **217.182.138.150**.
- c) Victim connects to 217.182.138.150 over unencrypted **HTTP** rather than HTTPS.
- d) Suspicious .exe file, **tkraw_Protected99.exe** downloaded by the victim.
- e) Victim OS – **Windows NT 6.1**, more vulnerable since old version, indicates exploiting vulnerability.
- f) Communication established with malicious IP.
- g) Data exfiltration confirmed after observing SMTP traffic which indicates exfiltration through emails.
- h) The malware establishes persistence and continues data exfiltration every 10 minutes indicating automated attacker control, thus confirming that the system is compromised.

III. Containment

1. Short-term containment

- The infected system was isolated from the network to stop communication with the attacker-controlled system.
- The malicious IP address and domain identified during analysis were blocked at firewall level to prevent further connections to other systems.
- Any possibly compromised user accounts were disabled to avoid potential exploit.

2. Long-term containment

- Network segmentation was deployed to prevent lateral movement of an attacker within the system.
- Access permission were reviewed and restricted according the principle of least privilege.

IV. Eradication

1. Malware Removal

- The identified malware executable file was completely removed from the infected system. System scans were performed to ensure no other malicious files were present.
- Sensitive information and credentials of user accounts that were potentially exposed during the attack, were asked to reset passwords to eradicate any chance of unauthorized access.
- Any changes made by the malware were identified, reversed and restored back to its clean state.

2. System hardening

- Unnecessary services were disabled. Security configurations were applied to prevent risk of future attacks.
- Firewall and other endpoint protection rules were strengthened to prevent execution of unauthorized files.

3. Vulnerability fixing

- Due to lack of monitoring controls, the attack leveraged use of unsecure HTTP for communication with an untrusted source.
- New security updates and patches were applied to address this.

V. Recovery

1. System Restoration

The affected system was restored to its normal state after eradicating the malware. This can be done with the help of clean backups.

2. Validation

- Post-recovery validation was done to ensure that there is no malicious content left in the system.
- System functionality was tested to ensure the normal operations were restored without any performance and security issues.

3. Monitoring

Enhanced monitoring was implemented to closely monitor for abnormal patterns or any signs of malware existence in DNS queries and communication over the network.

4. Business Continuity

After validating the system stability, critical business operations were resumed without any disruptions along with persistent monitoring.

5. Detection and Response Evaluation

1. Successful Detection

- HTTP payload delivery
- DNS communication
- Abnormal SMTP traffic
- Malicious IP Address and domain
- Attack Timeline

2. Missed Detection

Initial execution stage

3. False Positives

Possible during initial stage as it failed to detect malicious domain initially.

4. Time to Detect

Delayed

5. Time to Respond

Moderate

6. Attack VS Defense Mapping

ATTACK STAGE	RED TEAM	BLUE TEAM
Delivery	Malicious file via HTTP	Detected unusual HTTP traffic
Execution	Victim runs executable file	Suspicious file detected
Communication	DNS + IP communication	Abnormal DNS queries
Data Exfiltration	Exfiltration via SMTP	Detected unusual SMTP traffic

7. Gap Analysis

The analysis revealed several gaps in the security controls.

- Due to lack of monitoring controls, the attack leveraged use of unsecure HTTP for communication with an untrusted source.
- Detection of suspicious DNS queries and SMTP traffic was delayed, indicating insufficient real-time monitoring.
- The victim system used outdated OS **Windows NT 6.1**, which was a potential vulnerability.

```
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;  
Host: proforma-invoices.com\r\n  
Connection: Keep-Alive\r\n
```

Figure 7.

- Possible phishing or a social engineering attack thus indicating lack of user awareness.
- Additionally, SOC Analysts have to be familiar with latest tools, and deploy anti-malware software to detect and respond to attacks before they spread.

8. Mitigation Strategies

1. Block malicious content

Domain: proforma-invoices.com

IP Address: 217.182.138.150

2. Endpoint malware scanning and removal

- Perform infected host system scanning.
- Remove detected malware tkraw_Protected99.exe.
- Use updated Anti-malware/EDR tools.

3. Enforce HTTPS

- Restrict downloading over HTTP.
- Enforce HTTPS only downloading in web browsers.
- Enforce blocking suspicious domains from web.

4. Continuous monitoring and alerts

- Automatically block suspicious domains.
- Detect repeated queries and investigate.
- Monitor Smtip traffic.

5. User awareness

Perform employee training on identifying suspicious links, phishing attacks.

6. Use updated software

Avoid using Windows 7 and switch to newer versions to ensure system is free of vulnerabilities.

9. Lessons Learned

9.1. Incident Review

The impact of the attack included potential compromise of sensitive information as there was data exfiltration, unauthorized external communication which indicates weak network monitoring and detection.

9.2. Gap Analysis

- There was absence of strict network controls and real-time monitoring which may have stopped the attack in the previous stages causing lesser data compromise.
- Re-tuning the threshold for suspicious DNS queries and outbound SMTP traffic may have helped in identifying the attacker in advance.

9.3. Training and Awareness

- Awareness programs have to be conducted among employees to train them to identify malware, social engineering attacks and verify the sources before sharing sensitive information.
- Additionally, SOC Analysts have to be familiar with latest tools, and deploy anti-malware software to detect and respond to attacks before they spread.

9.4. Improvements

- Enhanced real-time security monitoring
- Employee training and awareness
- Anti-malware solutions
- Updated detection rules

9.5. Red + Blue Team Collaboration

- The collaboration between Red Team and Blue Team significantly improved the overall detection capability by validating real-world attacker techniques against existing defensive mechanisms. This approach helped identify security gaps in monitoring and provided mitigation strategies enabling the development of more effective detection strategies.

- Additionally, it enhanced awareness of attacker techniques, like malware delivery methods, C2C communication and data exfiltration strategies. This wider knowledge allows security teams to better anticipate, detect, and respond to similar threats in real-world environments.

10. Conclusion

The Purple team analysis gave an understanding of multi-stage attacks compromising a system that lacks proper monitoring and controls. Both red and blue team's perspectives made it evident how the right security controls could detect, delay, or prevent the attack.

Overall, it emphasizes the value of combining offensive and defensive approaches to build a more resilient and proactive security posture.